



IT SIMPLERA INSTITUTE INTERNSHIP PROGRAM

WEEK 05 REPORT

Malware Breaches Analysis Report

Submitted By

Name: Challa Madhumitha

Reg No: SOCB01-2121

Role: Soc Analyst Intern

Submission Date: 6th August 2026

Instructor: Zia Ullah

TABLE OF CONTENTS

S.No	Contents	Page No.
1	Introduction	3
2	Research Methodology	3
3	Malware Breach 1 – WannaCry Ransomware	3
4	Malware Breach 2 – NotPetya Malware	4
5	Malware Breach 3 – Emotet Banking Trojan	5
6	Malware Breach 4 – Agent Tesla Information Stealer	8
7	Malware Breach 5 – Ryuk Ransomware	11
8	Malware Breach 6 – LockBit Ransomware	11
9	Malware Breach 7 – BlackCat (ALPHV) Ransomware	12
10	Malware Breach 8 – REvil (Sodinokibi) Ransomware	12
11	Malware Breach 9 – DarkSide Ransomware	13
12	Malware Breach 10 – SolarWinds SUNBURST Supply Chain Attack	14
13	Conclusion	14

1. Objective

The objective of this task was to research and analyze ten significant real-world malware breaches that have been publicly documented by cybersecurity organizations and threat intelligence researchers. The purpose of this study is to understand the characteristics of different malware families, investigate how attackers initially compromise systems, analyze the techniques used for propagation, persistence, and payload execution, and assess their overall impact on organizations.

This report also examines the Indicators of Compromise (IOCs) associated with each malware breach, compares common attack patterns, evaluates both technical and business impacts, and develops a consolidated Incident Response reference that can be applied to similar cyber incidents. The research enhances practical knowledge of malware analysis, threat intelligence, digital forensics, and Security Operations Center (SOC) operations.

2. Research Methodology

The research for this report was conducted using publicly available threat intelligence reports, malware analysis reports, incident response case studies, and cybersecurity vendor publications. Trusted sources including **CISA**, **MITRE ATT&CK**, **Microsoft Security**, **CrowdStrike**, **Cisco Talos**, **Palo Alto Unit 42**, **MalwareBazaar**, and **VirusTotal** were used to collect technical and incident-related information.

Each malware breach was analyzed based on the following criteria:

- Malware family and classification
- Threat actor (where publicly attributed)
- Timeline of the incident
- Initial infection vector
- Technical behaviour and malware execution process
- Propagation mechanism
- Persistence mechanism
- Indicators of Compromise (IOCs)
- Business and technical impact
- Detection techniques
- Prevention and mitigation strategies
- Lessons learned

The collected information was compared to identify recurring attack patterns, common vulnerabilities, and defensive strategies that can strengthen Security Operations Center (SOC) monitoring and incident response capabilities.

3. Malware Breach 1 – WannaCry Ransomware



Figure 1: WannaCry Ransom Note

3.1 Background

WannaCry is one of the most significant ransomware outbreaks in cybersecurity history. The attack began on **12 May 2017** and rapidly spread across more than **150 countries**, infecting over **230,000 computers** within a short period. It primarily targeted Microsoft Windows systems that had not been patched against the **MS17-010** vulnerability affecting the SMBv1 protocol.

The malware caused widespread disruption across healthcare, transportation, telecommunications, manufacturing, education, and government sectors. Organizations including the **United Kingdom's National Health Service (NHS)**, **FedEx**, **Renault**, **Telefónica**, and **Deutsche Bahn** experienced operational downtime and financial losses due to encrypted systems and unavailable services.

3.2 Malware Overview

Attribute	Details
Malware Name	WannaCry
Malware Family	Ransomware
Malware Type	Cryptoworm (Self-propagating Ransomware)
First Detected	12 May 2017
Target Platform	Microsoft Windows
Primary Exploit	EternalBlue (MS17-010 SMBv1 Vulnerability)
Propagation Method	SMBv1 Worm using EternalBlue Exploit
Encryption Algorithm	AES-128 (File Encryption) and RSA-2048 (Key Encryption)
Programming Language	C++
File Extension Added	.WNCRY
Ransom Demand	Bitcoin (BTC)
Kill Switch Domain	Yes (Hardcoded Kill Switch Domain)
Primary Objective	Encrypt victim files and demand ransom payment
Associated Threat Actor	Lazarus Group (Public Attribution)

3.3 Threat Actor

Several cybersecurity agencies have publicly attributed the WannaCry campaign to the **Lazarus Group**, a North Korean state-sponsored threat actor. Although direct attribution remains based on intelligence analysis, multiple governments and security organizations have linked the malware to this advanced persistent threat (APT) group.

3.4 Timeline

Date	Event
April 2017	EternalBlue exploit leaked by Shadow Brokers
12 May 2017	WannaCry ransomware outbreak begins

13 May 2017	Kill-switch domain discovered
May 2017	Microsoft released emergency security updates

3.5 Attack Vector

The primary infection vector for WannaCry was exploitation of the **MS17-010 (EternalBlue)** vulnerability within Microsoft's **SMBv1** protocol.

Attack Process

1. The attacker scans the internet for vulnerable Windows systems.
2. The EternalBlue exploit is used to gain unauthorized access.
3. WannaCry is executed on the compromised system.
4. User files are encrypted.
5. The malware scans the local network for additional vulnerable systems.
6. The infection spreads automatically without requiring user interaction.

Unlike many ransomware campaigns, WannaCry primarily relied on exploiting vulnerable services rather than phishing emails.

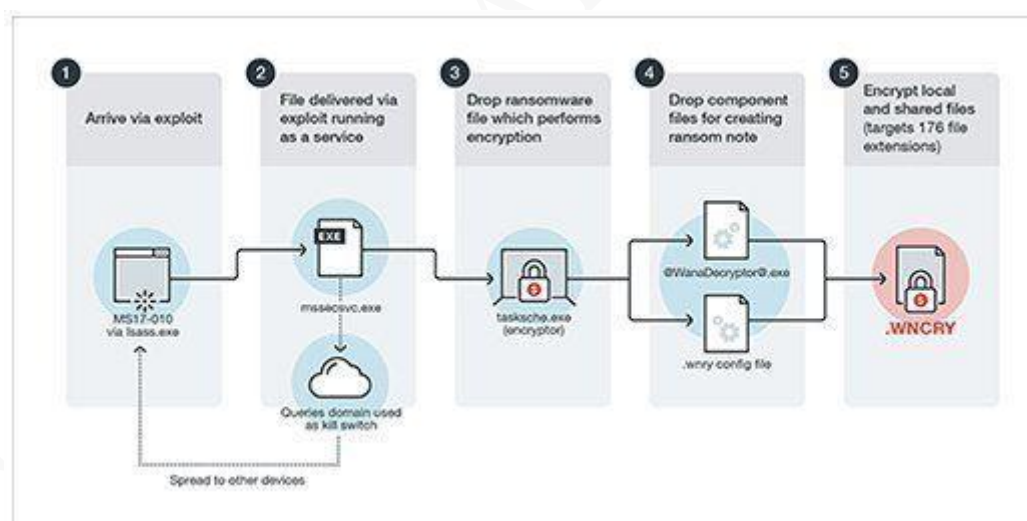


Figure 2: WannaCry Attack Flow

3.6 Initial Point of Compromise

The malware exploited Windows systems that exposed **TCP Port 445** with the SMBv1 protocol enabled and lacking the MS17-010 security update. After successful exploitation, the malware executed with elevated privileges and immediately initiated the encryption process.

3.7 Technical Behaviour

Once executed, WannaCry performed the following malicious activities:

- Generated encryption keys for victim files.
- Encrypted documents, images, databases, archives, and other user files.
- Renamed encrypted files using the **.WNCRY** extension.
- Displayed a Bitcoin ransom note requesting payment.
- Created scheduled tasks and Windows services to maintain execution.
- Scanned the local network for additional vulnerable hosts.
- Attempted to spread automatically using the EternalBlue exploit.
- Contacted a predefined kill-switch domain before continuing execution.

The combination of ransomware capabilities and worm-like propagation enabled WannaCry to spread rapidly across enterprise environments.

3.8 Indicators of Compromise (IOCs)

IOC Type	Observation
Malware Name	WannaCry
File Extension	.WNCRY
Protocol	SMBv1
Network Port	TCP 445
Registry Activity	Scheduled task and service creation
Ransom Note	@Please_Read_Me@.txt
Network Behaviour	SMB scanning across internal networks

3.9 Business Impact

The WannaCry attack significantly affected organizations worldwide by disrupting critical services and business operations.

Major impacts included:

- Cancellation of hospital appointments.
- Temporary shutdown of manufacturing facilities.

- Disruption of railway ticketing systems.
- Suspension of public services.
- Financial losses due to operational downtime and recovery activities.

The estimated global financial damage exceeded **USD 4 billion**.

3.10 Technical Impact

The technical impact of WannaCry included:

- Complete encryption of user files.
 - Loss of access to critical business systems.
 - Rapid lateral movement across internal networks.
 - Increased network traffic caused by automated scanning.
 - Large-scale emergency patch deployment.
 - System recovery using offline backups.
-

3.11 Detection Techniques

Security Operations Centers (SOCs) can detect WannaCry through:

- Monitoring unusual SMB traffic.
 - Detecting excessive TCP Port 445 scanning.
 - Identifying mass file encryption events.
 - Monitoring the creation of ransom notes.
 - Detecting abnormal scheduled task creation.
 - Using Endpoint Detection and Response (EDR) alerts.
-

3.12 MITRE ATT&CK Mapping

Technique ID	Technique
T1190	Exploit Public-Facing Application
T1021	Remote Services
T1486	Data Encrypted for Impact

T1105	Ingress Tool Transfer
T1053	Scheduled Task

3.13 Prevention and Mitigation

Organizations can reduce the risk of WannaCry infections by implementing the following security controls:

- Apply Microsoft security updates immediately.
 - Disable the SMBv1 protocol.
 - Restrict unnecessary access to TCP Port 445.
 - Maintain regular offline backups.
 - Deploy Endpoint Detection and Response (EDR) solutions.
 - Implement network segmentation.
 - Perform continuous vulnerability assessments.
 - Conduct regular cybersecurity awareness training.
-

3.14 Lessons Learned

The WannaCry outbreak highlighted the importance of proactive cybersecurity practices and effective vulnerability management. The incident demonstrated that delayed patch deployment can expose organizations to large-scale cyberattacks. Regular software updates, network segmentation, secure backup strategies, continuous monitoring, and rapid incident response are essential to reducing organizational risk. Additionally, collaboration and timely sharing of threat intelligence among security teams play a critical role in mitigating fast-spreading malware campaigns.

4. Malware Breach 2 – NotPetya Ransomware

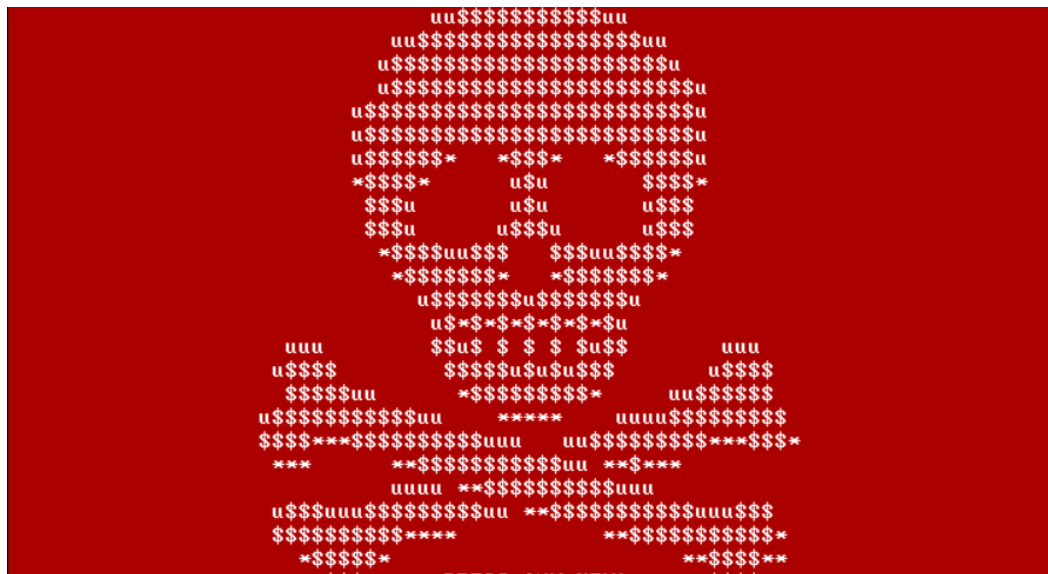


Figure 3 NotPetya Ransom Note

4.1 Background

NotPetya was a destructive malware attack that emerged on **27 June 2017**. Initially believed to be ransomware, further investigation revealed that its primary objective was to destroy data rather than generate ransom payments. Security researchers classified NotPetya as a **wiper malware** because its encryption mechanism was irreversible, making file recovery impossible even if victims paid the ransom.

The malware first targeted organizations in **Ukraine** through a compromised software update mechanism associated with the **MeDoc accounting software**. From there, it rapidly spread to multinational organizations worldwide, affecting logistics companies, healthcare providers, manufacturers, financial institutions, and government agencies.

Some of the major organizations impacted included **Maersk, Merck, FedEx (TNT Express), Mondelez International, Saint-Gobain**, and several Ukrainian government departments. The attack caused widespread operational disruption, resulting in billions of dollars in financial losses and highlighting the severe consequences of supply chain attacks.

4.2 Malware Overview

Attribute	Details
Malware Name	NotPetya
Malware Family	Wiper Malware
Malware Type	Destructive Malware (Ransomware-like Wiper)
Operating System	Microsoft Windows
Programming Language	C/C++
First Detected	27 June 2017
Threat Actor	Sandworm (GRU) (<i>publicly attributed</i>)
Initial Target	Ukrainian organizations using the MeDoc accounting software
Primary Distribution Method	Compromised MeDoc software update (Supply Chain Attack)
Propagation Methods	EternalBlue (MS17-010), EternalRomance, PsExec, Windows Management Instrumentation (WMI)
Primary Objective	Permanent data destruction and disruption of business operations
Encryption / Destructive Mechanism	Encrypts the Master File Table (MFT) and overwrites the Master Boot Record (MBR), making recovery impossible
Affected Industries	Logistics, Manufacturing, Healthcare, Finance, Government, Telecommunications
Major Organizations Affected	Maersk, Merck, FedEx (TNT Express), Mondelez International, Saint-Gobain, Ukrainian Government
Estimated Global Financial Impact	More than USD 10 billion

4.3 Threat Actor

Multiple intelligence agencies, including the United States, United Kingdom, Canada, Australia, and the European Union, publicly attributed the NotPetya attack to the Russian military intelligence agency (**GRU**), specifically the threat group commonly known as **Sandworm**.

The campaign is considered one of the most destructive state-sponsored cyberattacks ever documented.

4.4 Timeline

Date	Event
Early 2017	MeDoc software compromised
27 June 2017	NotPetya outbreak begins
Same Day	Global propagation across enterprise networks
Following Weeks	Recovery and forensic investigations initiated

4.5 Attack Vector

The initial infection occurred through a malicious software update distributed by the Ukrainian accounting application **MeDoc**.

Attack Process

1. Attackers compromised the MeDoc software update server.
2. Organizations installed the malicious update.
3. NotPetya executed on the victim system.
4. Credentials were harvested from memory.
5. Malware spread laterally using administrative tools and SMB exploits.
6. The Master Boot Record (MBR) was overwritten.
7. Systems became permanently unusable after reboot.

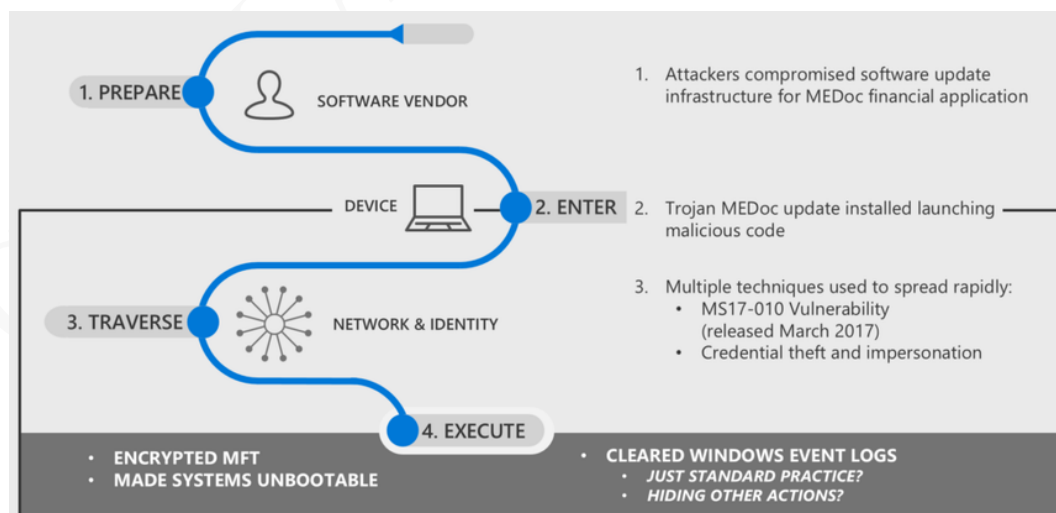


Figure 4 NotPetya Attack Flow

4.6 Initial Point of Compromise

The primary compromise occurred through the trusted software update mechanism of the MeDoc accounting application. Once installed, the malware obtained administrator privileges and began harvesting credentials before spreading throughout the enterprise network.

4.7 Technical Behaviour

After execution, NotPetya performed several destructive actions:

- Modified the Master Boot Record (MBR).
- Encrypted the Master File Table (MFT).
- Harvested credentials using memory dumping techniques.
- Used legitimate administrative tools such as **PsExec** and **Windows Management Instrumentation (WMI)** for lateral movement.
- Exploited the EternalBlue and EternalRomance SMB vulnerabilities to spread across vulnerable systems.
- Displayed a fake ransomware message requesting Bitcoin payment.
- Permanently damaged system data, preventing recovery.

Unlike traditional ransomware, NotPetya intentionally destroyed critical system structures, making decryption impossible.

4.8 Indicators of Compromise (IOCs)

IOC Type	Observation
Malware Name	NotPetya
Initial Infection	Compromised MeDoc software update
Network Protocol	SMB
Network Port	TCP 445
Lateral Movement	PsExec, WMI
Registry Activity	Boot configuration modifications
Disk Activity	Master Boot Record (MBR) overwrite
File System	Master File Table (MFT) encryption

4.9 Business Impact

NotPetya caused severe disruption across multiple industries.

Major business impacts included:

- Complete shutdown of global shipping operations.
- Manufacturing delays.
- Logistics disruptions.
- Financial transaction interruptions.
- Supply chain failures.
- Business continuity challenges.
- Significant recovery expenses.

The estimated global financial impact exceeded **USD 10 billion**, making it one of the costliest cyberattacks in history.

4.10 Technical Impact

Technical consequences included:

- Permanent destruction of file systems.
 - Corruption of the Master Boot Record.
 - Loss of operating system functionality.
 - Enterprise-wide lateral movement.
 - Credential theft.
 - Extensive downtime.
 - Large-scale system rebuilding.
-

4.11 Detection Techniques

Security teams can identify NotPetya activity through:

- Monitoring abnormal SMB traffic.
- Detecting unauthorized PsExec execution.
- Identifying suspicious WMI activity.
- Monitoring MBR modification attempts.

- Detecting credential dumping behavior.
 - Observing unexpected system reboots.
 - Endpoint Detection and Response (EDR) alerts.
-

4.12 MITRE ATT&CK Mapping

Technique ID	Technique
T1195	Supply Chain Compromise
T1003	OS Credential Dumping
T1021	Remote Services
T1047	Windows Management Instrumentation
T1569	System Services
T1485	Data Destruction
T1486	Data Encrypted for Impact

4.13 Prevention and Mitigation

Organizations can reduce the risk of similar attacks by implementing the following controls:

- Verify software updates using trusted sources.
 - Implement multi-factor authentication for privileged accounts.
 - Apply security patches promptly.
 - Disable unnecessary SMB services.
 - Restrict administrative tools such as PsExec.
 - Segment enterprise networks.
 - Monitor credential dumping activity.
 - Maintain secure offline backups.
 - Deploy Endpoint Detection and Response (EDR) solutions.
 - Perform continuous threat hunting.
-

4.14 Lessons Learned

The NotPetya attack demonstrated that trusted software supply chains can become effective attack vectors if compromised. Organizations learned that strong software integrity verification, proactive patch management, privileged access controls, network segmentation, and continuous monitoring are essential for reducing cyber risk. The incident also emphasized that cyberattacks may be designed purely for disruption rather than financial gain, highlighting the importance of comprehensive incident response planning and resilient business continuity strategies.

5. Malware Breach 3 – Emotet Banking Trojan

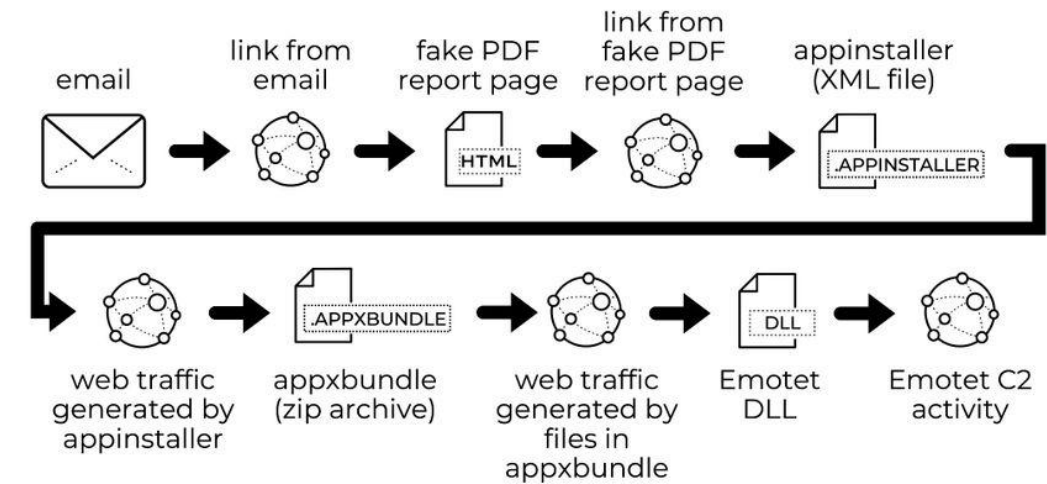


Figure 5 Emotet Infection Flow

5.1 Background

Emotet was first identified in **2014** as a banking Trojan designed to steal financial information from victims. Over time, it evolved into one of the world's most sophisticated malware delivery platforms, acting as a malware loader that enabled attackers to deploy additional malicious payloads such as TrickBot, Ryuk ransomware, QakBot, and other credential-stealing malware.

Emotet primarily spread through large-scale phishing email campaigns containing malicious Microsoft Office documents or hyperlinks. Once executed, the malware established persistence, stole sensitive information, spread laterally within enterprise networks, and downloaded additional malware modules.

The malware targeted government organizations, financial institutions, healthcare providers, educational institutions, and private enterprises worldwide. Due to its modular architecture and continuous updates, Emotet remained one of the most dangerous malware families until its infrastructure was disrupted during an international law enforcement operation in **January 2021**. However, later variants re-emerged through new phishing campaigns.

5.2 Malware Overview

Attribute	Details
Malware Name	Emotet
Malware Family	Banking Trojan / Malware Loader
Malware Type	Trojan
First Observed	2014

Operating System	Microsoft Windows
Primary Purpose	Credential Theft and Malware Distribution

5.3 Threat Actor

Emotet has been primarily associated with the cybercriminal group **TA542 (Mummy Spider)**. This financially motivated threat actor is known for operating large-scale phishing campaigns using Emotet as a malware distribution platform for ransomware and other malware families.

5.4 Timeline

Date	Event
2014	Emotet first identified as banking Trojan
2018	Expanded into malware distribution platform
2019	Became one of the most active malware campaigns globally
January 2021	Global law enforcement operation disrupted infrastructure
Late 2021	Emotet operations resumed with new phishing campaigns

5.5 Attack Vector

Emotet primarily infected victims through phishing emails containing malicious Microsoft Office attachments or hyperlinks.

Attack Process

1. Victim receives a phishing email.
2. User opens the malicious Office document.
3. Macros are enabled.
4. PowerShell downloads the Emotet payload.
5. Malware installs itself on the system.
6. Persistence mechanisms are established.
7. Credentials and emails are stolen.
8. Additional malware is downloaded.
9. Infection spreads to other systems.

The malware relied heavily on social engineering to convince users to execute malicious documents.

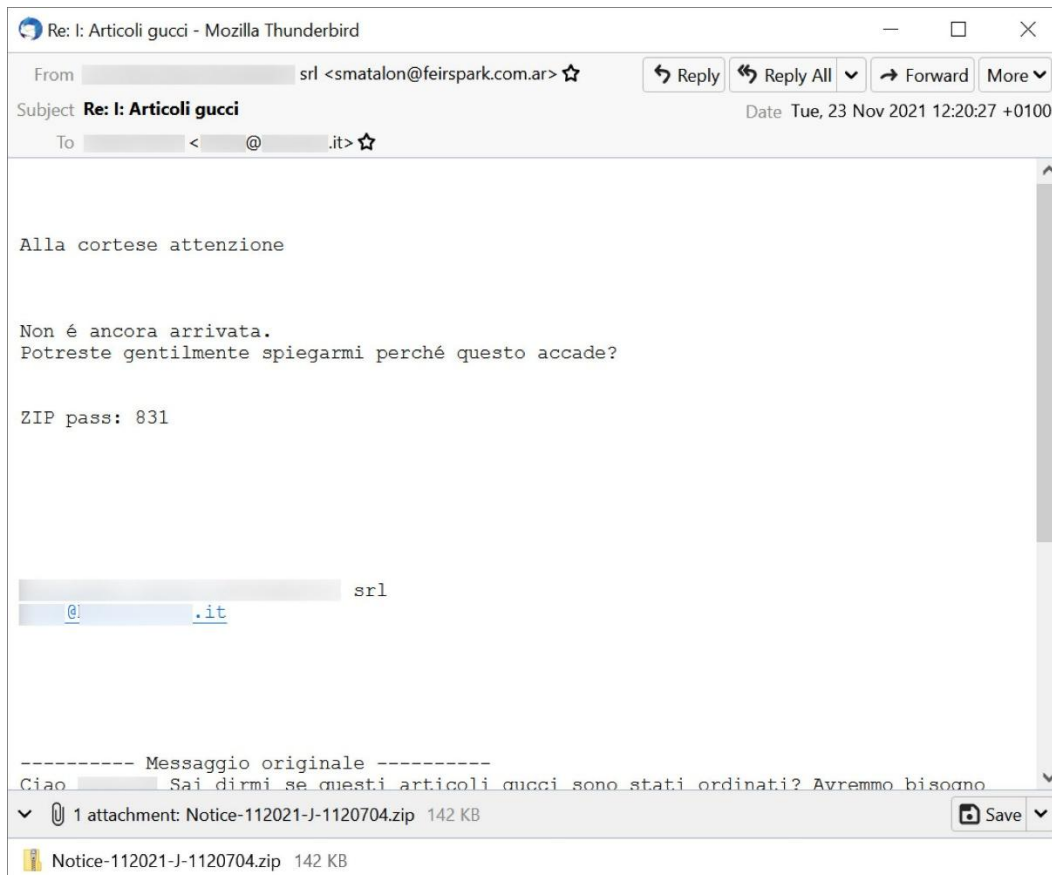


Figure 6 Example of an Emotet Phishing Email

.6 Initial Point of Compromise

he initial compromise typically occurred when users opened phishing email attachments and enabled malicious macros within Microsoft Word or Excel documents. This action triggered PowerShell commands that downloaded and executed the Emotet payload.

5.7 Technical Behaviour

Once executed, Emotet performed several malicious activities including:

- Establishing persistence through Windows Registry Run keys and scheduled tasks.
- Downloading additional malware modules.
- Stealing stored credentials.
- Harvesting email contacts.
- Collecting browser information.
- Performing network reconnaissance.

- Spreading laterally across enterprise networks.
- Communicating with remote Command-and-Control (C2) servers.
- Updating itself using modular components.

Its modular architecture allowed attackers to continuously add new capabilities without replacing the entire malware.

5.8 Indicators of Compromise (IOCs)

IOC Type	Observation
Malware Name	Emotet
Delivery Method	Phishing Emails
File Type	Malicious Microsoft Office Documents
Process	powershell.exe
Registry	Run Keys, Scheduled Tasks
Network Activity	Communication with Command-and-Control Servers
Payload	Downloads additional malware families

5.9 Business Impact

Emotet significantly affected organizations across multiple industries.

Major business impacts included:

- Credential theft.
- Financial fraud.
- Email account compromise.
- Large-scale phishing campaigns.
- Malware distribution within enterprise environments.
- Business disruption.
- Increased incident response costs.
- Deployment of ransomware following initial infection.

Organizations often experienced prolonged recovery efforts due to multiple malware infections delivered through Emotet.

5.10 Technical Impact

Technical consequences included:

- Credential theft.
 - Email harvesting.
 - Browser data theft.
 - Persistence through registry modifications.
 - Lateral movement across networks.
 - Download and execution of secondary malware.
 - Command-and-Control communication.
 - Increased attack surface within compromised environments.
-

5.11 Detection Techniques

Security Operations Centers (SOCs) can detect Emotet through:

- Monitoring phishing email activity.
 - Detecting PowerShell execution from Office applications.
 - Monitoring unusual registry modifications.
 - Identifying suspicious scheduled task creation.
 - Detecting communication with known Command-and-Control servers.
 - Monitoring abnormal outbound network traffic.
 - Endpoint Detection and Response (EDR) alerts.
 - Email security gateway alerts.
-

5.12 MITRE ATT&CK Mapping

Technique ID	Technique
T1566	Phishing
T1059.001	PowerShell
T1547	Boot or Logon Autostart Execution
T1003	OS Credential Dumping
T1105	Ingress Tool Transfer

T1071	Application Layer Protocol
T1021	Remote Services

5.13 Prevention and Mitigation

Organizations can reduce the risk of Emotet infections by implementing the following controls:

- Deploy advanced email filtering solutions.
 - Disable Office macros from untrusted sources.
 - Conduct regular phishing awareness training.
 - Enable Multi-Factor Authentication (MFA).
 - Restrict PowerShell execution where possible.
 - Maintain Endpoint Detection and Response (EDR) solutions.
 - Apply operating system and application security updates.
 - Monitor outbound network communications.
 - Implement network segmentation.
 - Perform continuous threat hunting.
-

5.14 Lessons Learned

The Emotet malware campaign demonstrated that phishing remains one of the most effective attack vectors used by cybercriminals. Organizations learned that user awareness, secure email gateways, endpoint monitoring, and rapid detection of suspicious PowerShell activity are essential to preventing successful malware infections. The campaign also highlighted the importance of monitoring for malware loaders, as they often serve as the initial stage for more destructive attacks such as ransomware deployment.

6. Malware Breach 4 – Agent Tesla Information Stealer

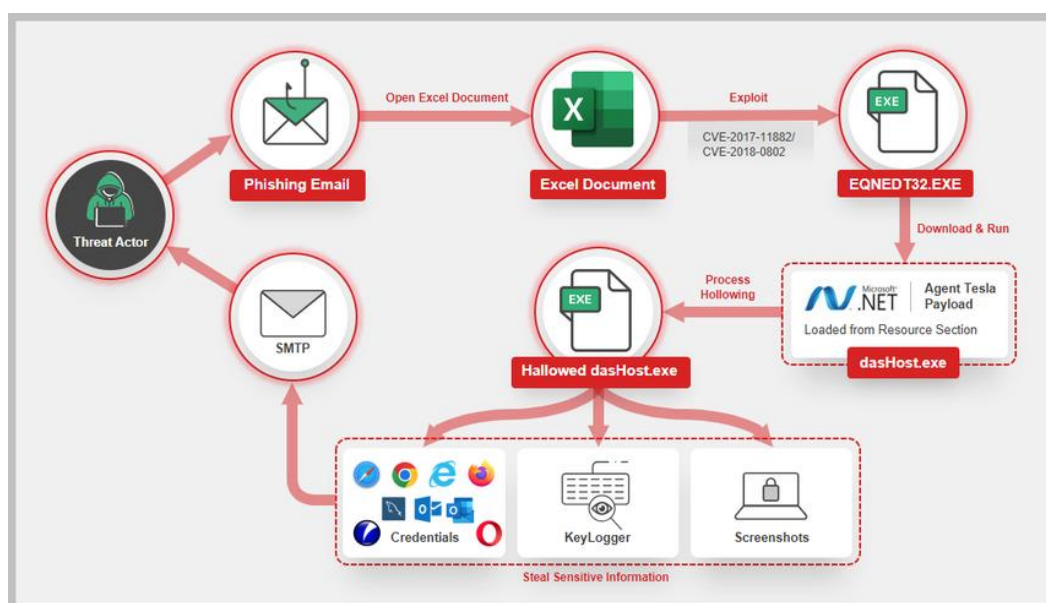


Figure 7 Agent Tesla Attack Lifecycle

6.1 Background

Agent Tesla is a sophisticated **Remote Access Trojan (RAT)** and **Information Stealer** first discovered in **2014**. It is designed to steal sensitive information such as usernames, passwords, browser credentials, email account details, keystrokes, clipboard data, and system information from infected Windows systems.

Unlike ransomware, Agent Tesla focuses on **cyber espionage and credential theft** rather than encrypting victim files. The malware is commonly distributed through phishing emails containing malicious Microsoft Office documents, compressed archives, or executable attachments. Once executed, it silently operates in the background while continuously collecting and exfiltrating sensitive information to attacker-controlled servers.

Agent Tesla has been widely used against government organizations, financial institutions, healthcare providers, educational institutions, and manufacturing companies worldwide due to its low cost and effectiveness in credential theft.

6.2 Malware Overview

Attribute	Details
Malware Name	Agent Tesla
Malware Family	Information Stealer / Remote Access Trojan (RAT)

Attribute	Details
Malware Type	Credential Stealer
First Observed	2014
Operating System	Microsoft Windows
Primary Objective	Credential Theft and Remote Access

6.3 Threat Actor

Agent Tesla is a **Malware-as-a-Service (MaaS)** tool that has been used by numerous financially motivated cybercriminal groups. Because it is sold on underground forums, it has been deployed in many unrelated phishing campaigns rather than being linked to a single threat actor.

6.4 Timeline

Date	Event
2014	Agent Tesla first identified
2016–2019	Rapid growth in phishing campaigns
2020	Significant increase during COVID-19 themed attacks
2021–Present	Continues to evolve with new evasion techniques

6.5 Attack Vector

Agent Tesla primarily spreads through phishing emails containing malicious attachments or download links.



Figure 8 Example of an Agent Tesla Phishing Email

Attack Process

1. The victim receives a phishing email.
2. The user opens the malicious attachment or executable.
3. Agent Tesla executes on the victim machine.
4. The malware establishes persistence.
5. Credentials, keystrokes, and system information are collected.
6. Stolen data is transmitted to attacker-controlled servers through SMTP, FTP, HTTP, or Telegram.

6.6 Initial Point of Compromise

The initial compromise occurs when the victim executes a malicious attachment received through phishing emails or downloads an infected executable disguised as a legitimate file. Once launched, the malware silently installs itself and begins collecting sensitive information.

6.7 Technical Behaviour

After successful execution, Agent Tesla performs the following malicious activities:

- Establishes persistence using Windows Registry Run keys or Scheduled Tasks.
- Records user keystrokes using a built-in keylogger.
- Steals credentials stored in web browsers.

- Extracts email credentials from Microsoft Outlook and other email clients.
- Captures clipboard contents.
- Collects system information, including hostname, operating system version, and installed software.
- Monitors user activity in real time.
- Sends stolen information to attacker-controlled servers using SMTP, FTP, HTTP, or Telegram.
- Operates silently to avoid user detection.

Unlike ransomware, Agent Tesla focuses on continuous surveillance and credential theft without interrupting the victim's normal activities.

6.8 Indicators of Compromise (IOCs)

IOC Type	Observation
Malware Name	Agent Tesla
File Type	Executable (.exe)
Delivery Method	Phishing Email
Registry Activity	Run Key Persistence
Process	AgentTesla.exe (name may vary)
Network Activity	SMTP, FTP, HTTP, Telegram communication
Data Theft	Browser credentials, email credentials, keystrokes, clipboard

6.9 Business Impact

Agent Tesla can have serious consequences for organizations by compromising confidential information and enabling further attacks.

Major impacts include:

- Theft of employee credentials.
- Unauthorized access to corporate email accounts.
- Exposure of confidential business information.
- Financial fraud using stolen credentials.
- Increased risk of ransomware deployment.
- Damage to organizational reputation.

- Compliance and regulatory violations.

6.10 Technical Impact

Technical consequences include:

- Persistent unauthorized access.
- Credential compromise.
- Keylogging of sensitive information.
- Email account compromise.
- Browser password theft.
- Continuous data exfiltration.
- Increased attack surface for future compromises.

6.11 Detection Techniques

SOC analysts can detect Agent Tesla by monitoring:

- Suspicious outbound SMTP or FTP traffic.
- Unknown processes accessing browser credential databases.
- Registry Run key modifications.
- Unexpected PowerShell or command-line activity.
- Communication with known malicious domains or IP addresses.
- Endpoint Detection and Response (EDR) alerts.
- Antivirus detections and behavioral analysis.

6.12 MITRE ATT&CK Mapping

Technique ID	Technique
T1566	Phishing
T1056.001	Keylogging
T1555	Credentials from Password Stores
T1115	Clipboard Data
T1547	Boot or Logon Autostart Execution

T1041	Exfiltration Over Command and Control Channel
T1071	Application Layer Protocol

6.13 Prevention and Mitigation

Organizations can reduce the risk of Agent Tesla infections by implementing the following security controls:

- Deploy advanced email security gateways.
 - Block executable attachments from unknown senders.
 - Enable Multi-Factor Authentication (MFA).
 - Keep operating systems and software updated.
 - Restrict macro execution in Microsoft Office.
 - Monitor outbound SMTP, FTP, and HTTP traffic.
 - Deploy Endpoint Detection and Response (EDR) solutions.
 - Conduct regular phishing awareness training.
 - Perform continuous security monitoring and threat hunting.
-

6.14 Lessons Learned

Agent Tesla demonstrates that information-stealing malware can remain undetected for extended periods while continuously collecting sensitive data. Organizations should prioritize email security, endpoint monitoring, user awareness training, and proactive threat hunting to identify malicious activity early. Continuous monitoring of credential access, outbound communications, and persistence mechanisms is essential to reduce the impact of credential theft and prevent follow-on attacks.

7. Malware Breach 5 – Ryuk Ransomware

```
Your network has been penetrated.

All files on each host in the network have been encrypted with a strong algorithm.

Backups were either encrypted or deleted or backup disks were formatted.
Shadow copies also removed, so F8 or any other methods may damage encrypted data but
not recover.

We exclusively have decryption software for your situation
No decryption software is available in the public.

DO NOT RESET OR SHUTDOWN - files may be damaged.
DO NOT RENAME OR MOVE the encrypted and readme files.
DO NOT DELETE readme files.
This may lead to the impossibility of recovery of the certain files.

To get info (decrypt your files) contact us at
KurtSchweickardt@protonmail.com
or
KurtSchweickardt@tutanota.com

BTC wallet:
14hVKm7Ft2rxDBFTNkkRC3kGstMGp2A4hk

Ryuk
No system is safe
```

Figure 9 Ryuk Ransom Note

7.1 Background

Ryuk is a sophisticated ransomware family that first appeared in **August 2018**. It is known for targeting large organizations, including hospitals, financial institutions, manufacturing companies, educational institutions, and government agencies. Unlike mass-distributed ransomware, Ryuk focuses on **high-value enterprise targets**, where attackers demand substantial ransom payments in cryptocurrency.

Ryuk is commonly deployed after an initial compromise by malware such as **Emotet** and **TrickBot**. Once attackers gain access to a victim's network, they perform reconnaissance, escalate privileges, disable security tools, and deploy Ryuk across multiple systems simultaneously. This coordinated approach maximizes operational disruption and increases the likelihood of ransom payment.

7.2 Malware Overview

Attribute	Details
Malware Name	Ryuk
Malware Family	Ransomware

Malware Type	Crypto Ransomware
First Observed	August 2018
Operating System	Microsoft Windows
Primary Objective	Encrypt Enterprise Data and Demand Ransom

7.3 Threat Actor

Ryuk has been associated with the cybercriminal group **Wizard Spider**, a financially motivated threat actor known for operating TrickBot, BazarLoader, and Conti ransomware campaigns. The group frequently uses Ryuk as the final payload after compromising enterprise networks.

7.4 Timeline

Date	Event
August 2018	Ryuk ransomware first detected
2019	Large-scale enterprise attacks increase
2020	Numerous healthcare organizations targeted during COVID-19
2021	Ryuk operations gradually replaced by Conti ransomware campaigns

7.5 Attack Vector

Ryuk infections typically begin through phishing emails or malware loaders such as Emotet and TrickBot.

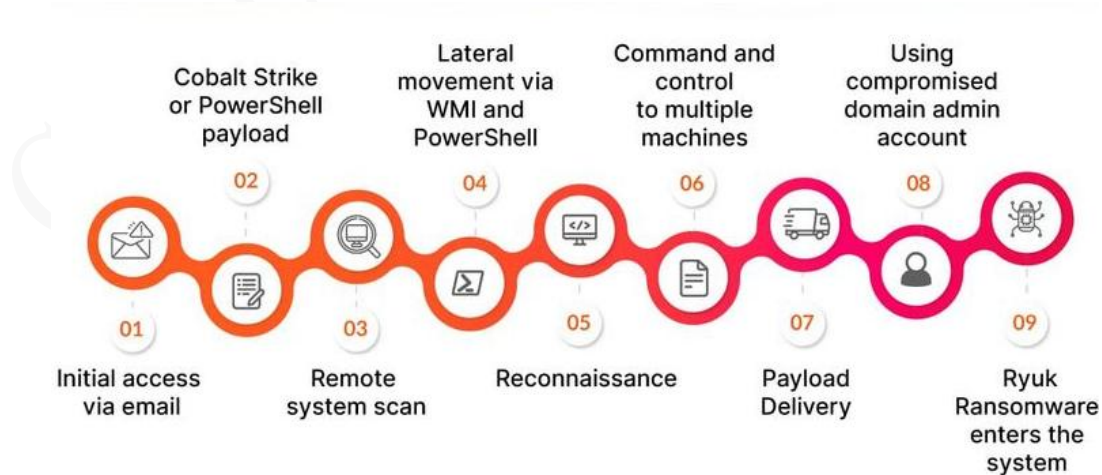


Figure 10 Ryuk Attack Chain

Attack Process

1. Victim receives a phishing email.
 2. Emotet infects the system.
 3. TrickBot is downloaded.
 4. Attackers perform reconnaissance.
 5. Administrative privileges are obtained.
 6. Lateral movement occurs across the network.
 7. Security software is disabled.
 8. Ryuk encrypts files on multiple systems.
 9. A ransom note is displayed.
-

7.6 Initial Point of Compromise

The initial compromise usually occurs through phishing emails containing malicious attachments or links. After execution, malware loaders establish persistence and provide attackers with remote access to the organization's network before Ryuk is deployed.

7.7 Technical Behaviour

After deployment, Ryuk performs the following malicious activities:

- Terminates backup and antivirus processes.
- Deletes Windows Shadow Volume Copies.
- Encrypts files using strong encryption algorithms.
- Appends a Ryuk-specific extension to encrypted files.
- Drops ransom notes in affected directories.
- Prevents recovery by deleting backup data.
- Targets network shares and mapped drives.
- Encrypts servers and workstations simultaneously.

Ryuk is manually deployed by attackers after careful network reconnaissance, making it highly effective against enterprise environments.

7.8 Indicators of Compromise (IOCs)

IOC Type	Observation
Malware Name	Ryuk
File Extension	.RYK or variant-specific extensions
Delivery Method	Emotet / TrickBot / Phishing
Registry Activity	Service and startup modifications
Process Activity	Backup service termination
File System	Shadow Copy deletion
Network Activity	Lateral movement across internal systems

7.9 Business Impact

Ryuk has caused significant financial and operational damage worldwide.

Major impacts include:

- Enterprise-wide business interruption.
- Hospital service disruptions.
- Manufacturing downtime.
- Loss of access to critical systems.
- Multi-million-dollar ransom demands.
- Reputation damage.
- Increased recovery and incident response costs.

Several organizations experienced prolonged outages requiring complete system rebuilds.

7.10 Technical Impact

Technical consequences included:

- Encryption of enterprise file servers.
- Deletion of backup copies.
- Loss of business-critical data.
- Domain-wide ransomware deployment.
- Service outages.
- Administrative account compromise.

- Large-scale recovery operations.

7.11 Detection Techniques

Security teams can detect Ryuk through:

- Monitoring PowerShell activity.
- Detecting Shadow Copy deletion.
- Identifying mass file encryption.
- Monitoring suspicious PsExec activity.
- Detecting abnormal administrative logins.
- Monitoring lateral movement using SMB.
- Endpoint Detection and Response (EDR) alerts.

7.12 MITRE ATT&CK Mapping

Technique ID	Technique
T1566	Phishing
T1486	Data Encrypted for Impact
T1490	Inhibit System Recovery
T1059	Command and Scripting Interpreter
T1021	Remote Services
T1078	Valid Accounts
T1105	Ingress Tool Transfer

7.13 Prevention and Mitigation

Organizations can reduce the risk of Ryuk infections by implementing the following security measures:

- Deploy advanced email filtering solutions.
- Enable Multi-Factor Authentication (MFA).
- Restrict administrative privileges.
- Maintain secure offline backups.

- Disable unnecessary PowerShell execution.
 - Implement network segmentation.
 - Deploy Endpoint Detection and Response (EDR).
 - Monitor privileged account activity.
 - Conduct regular vulnerability assessments.
 - Perform continuous threat hunting.
-

7.14 Lessons Learned

Ryuk demonstrated that ransomware attacks are often the final stage of a multi-step intrusion rather than an isolated event. Organizations should focus on detecting early indicators such as phishing attempts, malware loaders, credential theft, and lateral movement before ransomware is deployed. Effective backup strategies, privileged access management, continuous monitoring, and rapid incident response are critical for minimizing the impact of enterprise ransomware attacks.

8. Malware Breach 6 – LockBit Ransomware

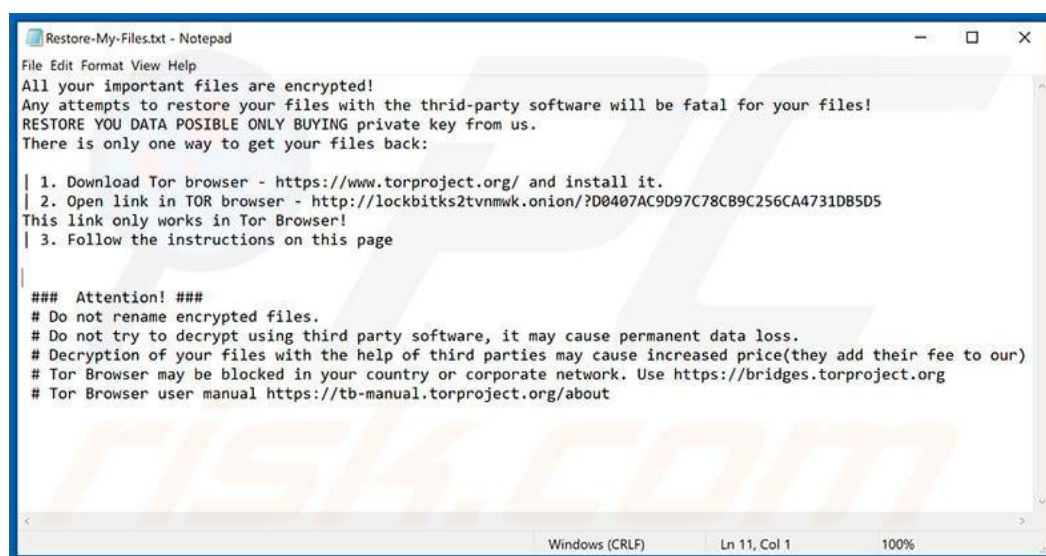


Figure 11 LockBit Ransom Note

8.1 Background

LockBit is one of the most active and sophisticated ransomware families in recent years. First identified in **2019**, it operates under the **Ransomware-as-a-Service (RaaS)** model, allowing affiliates to launch attacks using the LockBit infrastructure in exchange for a share of the ransom payments. The malware targets organizations of all sizes across industries including healthcare, finance, manufacturing, education, government, and critical infrastructure.

Unlike traditional ransomware, LockBit automates many stages of the attack process, enabling rapid encryption of enterprise networks. Before encrypting files, attackers often exfiltrate sensitive data and threaten to publish it on dedicated leak websites if the ransom is not paid. This double extortion strategy significantly increases pressure on victims.

LockBit has been responsible for thousands of attacks worldwide and has generated hundreds of millions of dollars in ransom payments before major international law enforcement operations disrupted parts of its infrastructure in 2024.

8.2 Malware Overview

Attribute	Details
Malware Name	LockBit
Malware Family	Ransomware
Malware Type	Ransomware-as-a-Service (RaaS)

First Observed	2019
Operating System	Microsoft Windows, Linux, VMware ESXi
Primary Objective	File Encryption and Data Extortion

8.3 Threat Actor

LockBit is operated by the **LockBit Ransomware Group**, which provides ransomware infrastructure to multiple affiliates under the Ransomware-as-a-Service (RaaS) model. Different affiliates conduct attacks using the same ransomware platform.

8.4 Timeline

Date	Event
2019	LockBit first discovered
2020	Rapid increase in ransomware campaigns
2021	LockBit 2.0 released
2022	LockBit 3.0 (LockBit Black) launched
2024	International law enforcement disrupts LockBit infrastructure

8.5 Attack Vector

LockBit infections typically begin through compromised credentials, phishing emails, Remote Desktop Protocol (RDP) attacks, VPN vulnerabilities, or exploitation of unpatched systems.

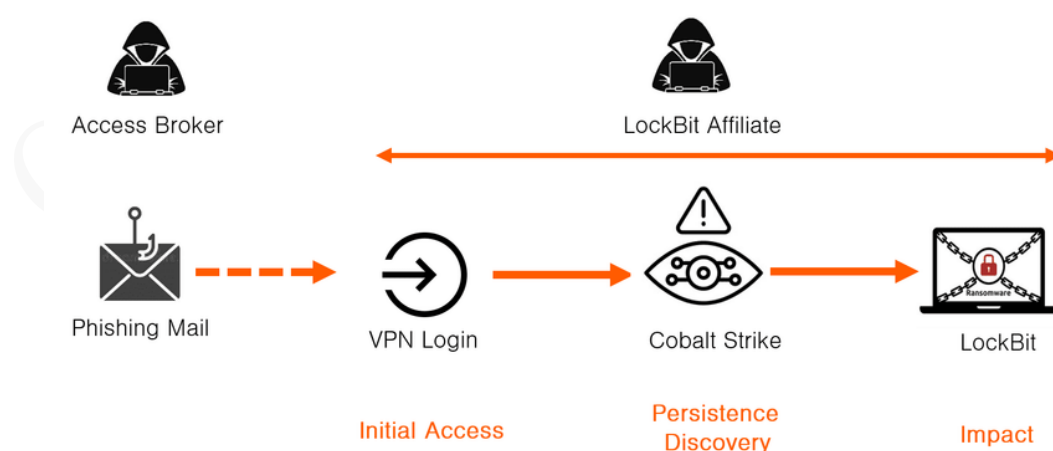


Figure 12 LockBit Attack Chain

Attack Process

1. Attackers gain initial access through phishing, VPN vulnerabilities, or exposed RDP services.
 2. Privileges are escalated within the environment.
 3. Network reconnaissance is performed.
 4. Sensitive data is collected and exfiltrated.
 5. Security tools and backups are disabled.
 6. LockBit encrypts files across multiple systems.
 7. A ransom note is displayed demanding cryptocurrency payment.
-

8.6 Initial Point of Compromise

The initial compromise commonly occurs through stolen credentials, phishing emails, vulnerable VPN appliances, or exposed RDP services. Once attackers obtain access, they move laterally across the network and prepare the environment before deploying ransomware.

8.7 Technical Behaviour

Once executed, LockBit performs several malicious activities:

- Enumerates local and network drives.
 - Terminates antivirus and backup services.
 - Deletes Windows Shadow Volume Copies.
 - Encrypts files using strong cryptographic algorithms.
 - Changes file extensions to LockBit-specific extensions.
 - Drops ransom notes in encrypted directories.
 - Exfiltrates sensitive data before encryption.
 - Uses multithreaded encryption to speed up the attack.
 - Avoids encrypting critical system files to keep the operating system functional.
-

8.8 Indicators of Compromise (IOCs)

IOC Type	Observation
----------	-------------

Malware Name	LockBit
File Extension	.lockbit (or variant-specific extensions)
Delivery Method	Phishing, RDP, VPN Exploitation
Registry Activity	Service modifications
Process Activity	Backup and antivirus termination
File System	Shadow Copy deletion
Network Activity	Data exfiltration to attacker-controlled servers

8.9 Business Impact

LockBit attacks have caused severe disruption across numerous industries.

Major impacts include:

- Enterprise-wide operational downtime.
- Loss of sensitive business data.
- Financial losses from ransom demands.
- Regulatory penalties due to data breaches.
- Reputational damage.
- Business continuity interruptions.
- Increased cybersecurity recovery costs.

8.10 Technical Impact

Technical consequences included:

- Large-scale file encryption.
 - Data exfiltration before encryption.
 - Deletion of recovery mechanisms.
 - Lateral movement across enterprise networks.
 - Compromise of administrative accounts.
 - Service interruptions.
 - Extensive forensic investigations and recovery efforts.
-

8.11 Detection Techniques

SOC analysts can detect LockBit activity through:

- Monitoring abnormal RDP login attempts.
- Detecting suspicious PowerShell or command-line activity.
- Monitoring Shadow Copy deletion events.
- Identifying mass file encryption.
- Detecting unusual outbound data transfers.
- Monitoring privilege escalation activities.
- Endpoint Detection and Response (EDR) alerts.

8.12 MITRE ATT&CK Mapping

Technique ID	Technique
T1566	Phishing
T1078	Valid Accounts
T1021	Remote Services
T1486	Data Encrypted for Impact
T1490	Inhibit System Recovery
T1041	Exfiltration Over Command and Control Channel
T1059	Command and Scripting Interpreter

8.13 Prevention and Mitigation

Organizations can reduce the risk of LockBit attacks by implementing the following security controls:

- Enable Multi-Factor Authentication (MFA).
- Restrict Remote Desktop Protocol (RDP) access.
- Apply security updates promptly.
- Monitor privileged account activity.
- Maintain secure offline backups.
- Deploy Endpoint Detection and Response (EDR) solutions.

- Segment enterprise networks.
 - Conduct regular vulnerability assessments.
 - Monitor outbound network traffic for data exfiltration.
 - Perform continuous threat hunting.
-

8.14 Lessons Learned

LockBit demonstrated that modern ransomware attacks combine data theft with file encryption to maximize pressure on victims. Organizations must focus on early detection, secure remote access, network segmentation, privileged access management, regular backups, and continuous monitoring. A proactive security posture and well-tested incident response plan are essential for minimizing the impact of ransomware attacks.

9. Malware Breach 7 – BlackCat (ALPHV) Ransomware

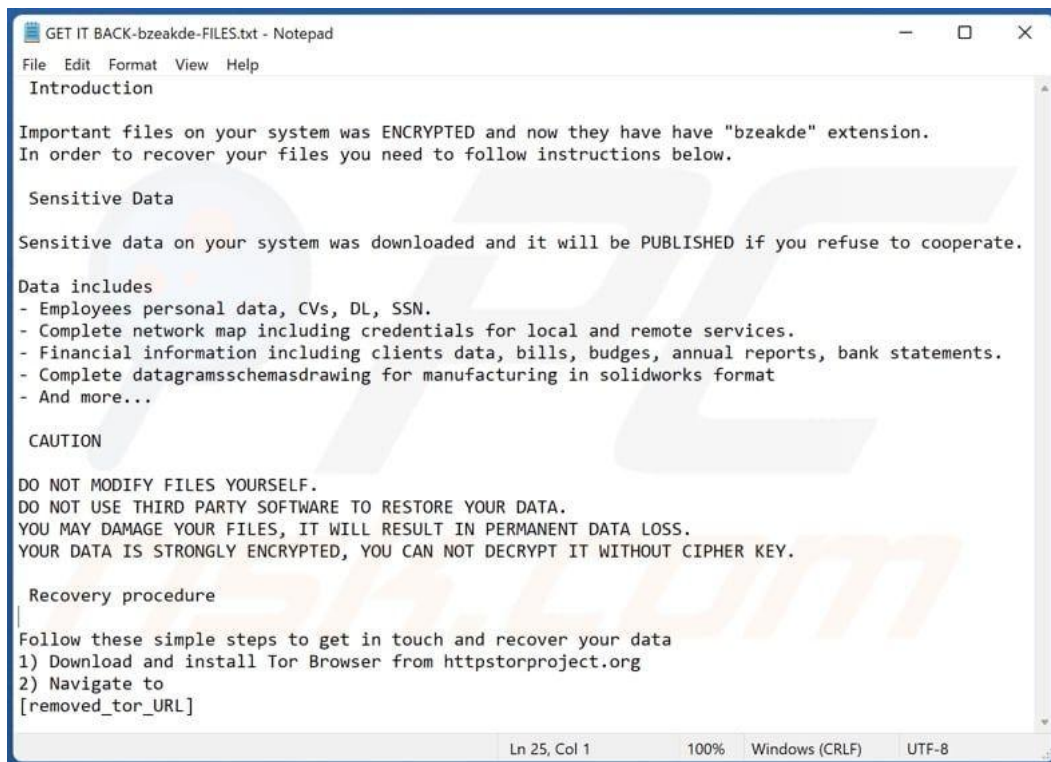


Figure 13 BlackCat (ALPHV) Ransom Note

9.1 Background

BlackCat, also known as **ALPHV**, is a sophisticated **Ransomware-as-a-Service (RaaS)** operation that first appeared in **November 2021**. It quickly became one of the most dangerous ransomware families due to its advanced capabilities, cross-platform support, and highly organized affiliate program. Unlike many earlier ransomware families, BlackCat was developed using the **Rust programming language**, allowing it to operate efficiently across Windows and Linux environments.

BlackCat attacks organizations in healthcare, finance, manufacturing, energy, education, telecommunications, and government sectors. Before encrypting files, attackers typically steal sensitive data and threaten to publish it on dedicated leak sites if the ransom is not paid. This **double-extortion** technique significantly increases pressure on victims.

The ransomware has been linked to numerous high-profile attacks worldwide, causing operational disruption, financial losses, and exposure of confidential information.

9.2 Malware Overview

Attribute	Details
-----------	---------

Malware Name	BlackCat (ALPHV)
Malware Family	Ransomware
Malware Type	Ransomware-as-a-Service (RaaS)
First Observed	November 2021
Programming Language	Rust
Operating Systems	Windows and Linux
Primary Objective	Data Theft and File Encryption

9.3 Threat Actor

BlackCat is operated by the **ALPHV Ransomware Group**, a financially motivated cybercriminal organization that provides ransomware services to affiliates. The group is known for using advanced intrusion techniques and double-extortion tactics to maximize financial gain.

9.4 Timeline

Date	Event
November 2021	BlackCat ransomware first detected
2022	Rapid increase in global ransomware campaigns
2023	Several high-profile enterprise attacks reported
2024	International law enforcement operations targeted ALPHV infrastructure

9.5 Attack Vector

BlackCat typically gains initial access through phishing emails, stolen credentials, Remote Desktop Protocol (RDP), Virtual Private Network (VPN) vulnerabilities, or exploitation of unpatched internet-facing systems.

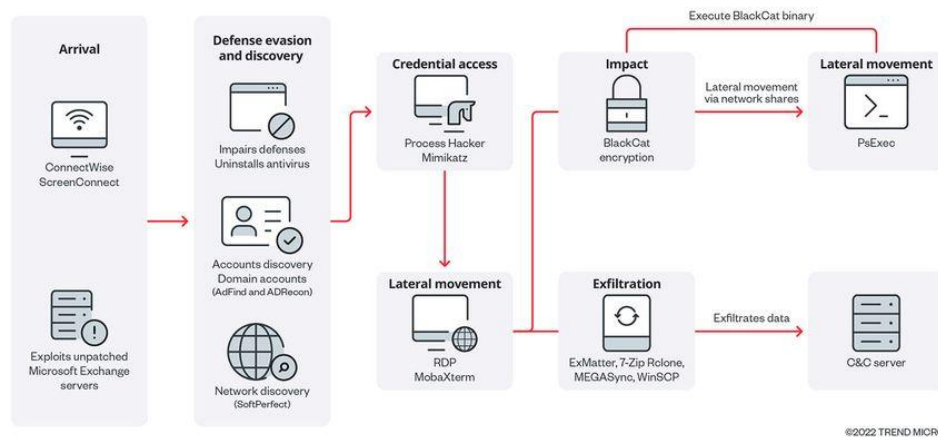


Figure 14 BlackCat Attack Chain

Attack Process

1. Attackers obtain initial access through phishing, VPN exploitation, or compromised credentials.
2. Privileges are escalated.
3. Internal network reconnaissance is performed.
4. Sensitive files are collected and exfiltrated.
5. Security tools and backup services are disabled.
6. BlackCat encrypts files across the enterprise.
7. A ransom note is displayed, demanding cryptocurrency payment.

9.6 Initial Point of Compromise

The initial compromise usually occurs through compromised user credentials, phishing campaigns, vulnerable VPN appliances, or exposed RDP services. Once attackers establish access, they move laterally through the network before deploying the ransomware payload.

9.7 Technical Behaviour

After execution, BlackCat performs the following malicious activities:

- Enumerates local and network storage devices.
- Terminates antivirus and backup-related services.
- Deletes Windows Shadow Volume Copies.
- Exfiltrates confidential business data.

- Encrypts files using advanced encryption algorithms.
 - Changes file extensions to BlackCat-specific extensions.
 - Creates ransom notes in affected directories.
 - Uses multithreaded encryption for faster execution.
 - Avoids encrypting essential operating system files to maintain system functionality.
-

9.8 Indicators of Compromise (IOCs)

IOC Type	Observation
Malware Name	BlackCat (ALPHV)
File Extension	.alphv or campaign-specific extensions
Delivery Method	Phishing, RDP, VPN Exploitation
Registry Activity	Service modifications
Process Activity	Antivirus and backup termination
File System	Shadow Copy deletion
Network Activity	Large outbound data transfers before encryption

9.9 Business Impact

BlackCat attacks have significantly affected organizations worldwide.

Major impacts include:

- Large-scale operational downtime.
 - Theft of confidential customer and business data.
 - Regulatory compliance violations.
 - Financial losses due to ransom demands and recovery costs.
 - Business interruption across multiple departments.
 - Damage to organizational reputation.
 - Increased cybersecurity remediation expenses.
-

9.10 Technical Impact

Technical consequences included:

- Enterprise-wide file encryption.

- Data exfiltration before encryption.
 - Removal of backup recovery mechanisms.
 - Lateral movement across enterprise environments.
 - Compromise of privileged accounts.
 - Service outages and operational disruption.
 - Extensive forensic investigations and system recovery.
-

9.11 Detection Techniques

Security teams can detect BlackCat activity through:

- Monitoring suspicious authentication attempts.
 - Detecting unusual privilege escalation.
 - Monitoring large outbound data transfers.
 - Identifying Shadow Copy deletion.
 - Detecting abnormal PowerShell and command-line execution.
 - Monitoring file encryption activity.
 - Endpoint Detection and Response (EDR) alerts.
 - Security Information and Event Management (SIEM) correlation rules.
-

9.12 MITRE ATT&CK Mapping

Technique ID	Technique
T1566	Phishing
T1078	Valid Accounts
T1021	Remote Services
T1486	Data Encrypted for Impact
T1490	Inhibit System Recovery
T1041	Exfiltration Over Command and Control Channel
T1059	Command and Scripting Interpreter

9.13 Prevention and Mitigation

Organizations can reduce the risk of BlackCat attacks by implementing the following security controls:

- Enable Multi-Factor Authentication (MFA).
 - Restrict Remote Desktop Protocol (RDP) access.
 - Apply software updates and security patches promptly.
 - Monitor privileged user accounts.
 - Maintain offline and immutable backups.
 - Deploy Endpoint Detection and Response (EDR) solutions.
 - Implement network segmentation.
 - Monitor outbound traffic for suspicious data transfers.
 - Conduct regular vulnerability assessments.
 - Perform continuous security monitoring and threat hunting.
-

9.14 Lessons Learned

BlackCat demonstrated that modern ransomware campaigns combine data theft with encryption to maximize leverage over victims. Organizations must prioritize identity security, network segmentation, secure remote access, continuous monitoring, and rapid incident response. Regular backups, employee security awareness, and proactive threat hunting remain critical for reducing the impact of ransomware attacks.

10. Malware Breach 8 – REvil (Sodinokibi) Ransomware

```

---== Welcome. Again. ===---
[+] Whats Happen? [+]
Your files are encrypted, and currently unavailable. You can check it: all files on your computer has extension s8rw9hj520.
By the way, everything is possible to recover (restore), but you need to follow our instructions. Otherwise, you cant return your data (NEVER).
[+] What guarantees? [+]
Its just a business. We absolutely do not care about you and your deals, except getting benefits. If we do not do our work and liabilities -
nobody will not cooperate with us. Its not in our interests.
To check the ability of returning files, You should go to our website. There you can decrypt one file for free. That is our guarantee.
If you will not cooperate with our service - for us, its does not matter. But you will lose your time and data, cause just we have the private
key. In practise - time is much more valuable than money.
[+] How to get access on website? [+]
You have two ways:
1) [Recommended] Using a TOR browser!
a) Download and install TOR browser from this site: https://torproject.org/
b) Open our website: http://applebzu47wgazapdqks6vrcv6zcnjppkbxb6wketf56nf6aq2nmyoyd.onion/A308E070885E786
2) If TOR blocked in your country, try to use VPN! But you can use our secondary website. For this:
a) Open your any browser (Chrome, Firefox, Opera, IE, Edge)
b) Open our secondary website: http://decryptor.top/A308E070885E786
Warning: secondary website can be blocked, thats why first variant much better and more available.
When you open our website, put the following data in the input form:
Key:
jKi+umH7EaLsM34j0ImnutP434kKFJD131CL6JTS0NfhrYJ3x/1CvBGEYGMfrczXY
I/Itvy2fIdGH1zHhuZghoqx30m8NBmqYgSpEF2NRBXAw0M6jCatfVdsAH3VMVX
Y5fpaQxU/XL6kK6mBAq9v9hXpx8VgXqde6S5n2a3+1ZiJjxi2F6n+Et/wM3dXD
Y118tOcIiM3b6I2kiE2yJIMFSADR+1bZdPwX1h+LlkccrIngSVmHJR442yE0Nc6o
pV59mRyJ80LmnzvsbzrSeGF6xWmQyKXX/eKJH3vb4CFu7w2Pb3iWn4fmiGr5B79
a0n76/a+SGchF+hBDis8Inic+02/fic1uLbFE+7n3SVKWmdn9T6Lk7/7f3fK5E1

```

Figure 15 REvil Ransom Note

10.1 Background

REvil, also known as **Sodinokibi**, is one of the most sophisticated **Ransomware-as-a-Service (RaaS)** families to emerge in recent years. First identified in **April 2019**, REvil rapidly gained prominence by targeting large enterprises, managed service providers (MSPs), healthcare organizations, financial institutions, government agencies, and critical infrastructure.

REvil became particularly well known for conducting **double-extortion attacks**, in which attackers first steal confidential information before encrypting victim systems. If organizations refuse to pay the ransom, the stolen data is published on dedicated leak websites, increasing financial and reputational damage.

Some of the most significant REvil attacks include the **JBS Foods ransomware attack (2021)** and the **Kaseya VSA supply chain attack (2021)**, which affected thousands of organizations worldwide.

10.2 Malware Overview

Attribute	Details
Malware Name	REvil (Sodinokibi)
Malware Family	Ransomware
Malware Type	Ransomware-as-a-Service (RaaS)

Attribute	Details
First Observed	April 2019
Operating System	Microsoft Windows
Primary Objective	File Encryption and Data Extortion

10.3 Threat Actor

REvil is operated by the **REvil cybercriminal group**, also known as **Sodinokibi**, which provides ransomware infrastructure to multiple affiliates under the Ransomware-as-a-Service (RaaS) business model. The group is financially motivated and has been responsible for several high-profile ransomware campaigns.

10.4 Timeline

Date	Event
April 2019	REvil ransomware first detected
2020	Large-scale enterprise attacks increase
May 2021	JBS Foods ransomware attack
July 2021	Kaseya VSA supply chain attack
Late 2021	International law enforcement disrupts REvil infrastructure

10.5 Attack Vector

REvil commonly gains access through phishing emails, Remote Desktop Protocol (RDP), software vulnerabilities, compromised credentials, and supply chain compromises.

REvil Ransomware Attack Chain

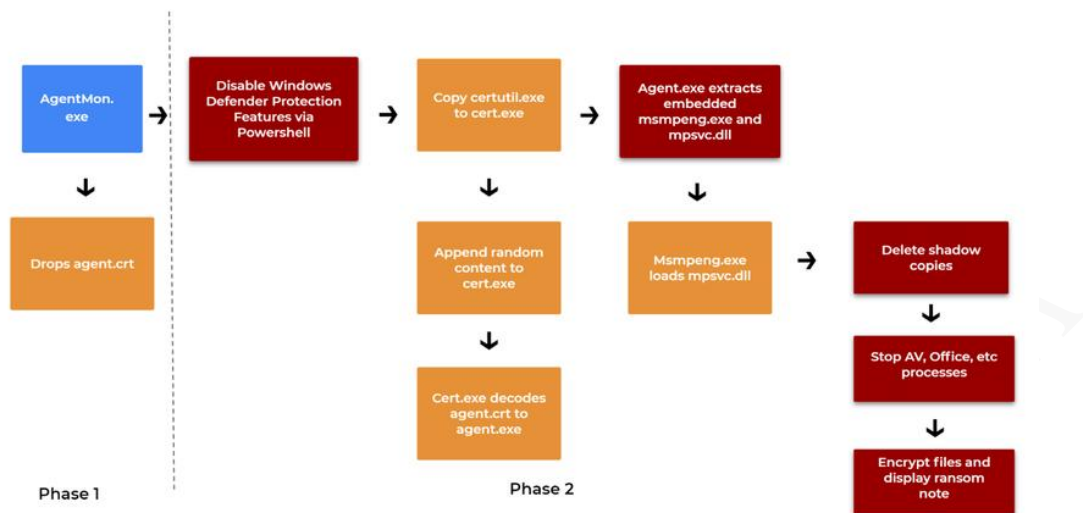


Figure 16 REvil Attack Chain

Attack Process

1. Attackers gain initial access through phishing, RDP compromise, VPN vulnerabilities, or exploited software.
2. Administrative privileges are obtained.
3. Internal systems are identified through network reconnaissance.
4. Sensitive data is collected and exfiltrated.
5. Security software and backup mechanisms are disabled.
6. REvil encrypts files across the network.
7. Victims receive a ransom note demanding cryptocurrency payment.

10.6 Initial Point of Compromise

The initial compromise generally occurs through phishing emails, exposed RDP services, vulnerable VPN appliances, or exploitation of software vulnerabilities. In supply chain incidents such as the Kaseya attack, compromised management software distributed the ransomware to downstream organizations.

10.7 Technical Behaviour

After execution, REvil performs several malicious activities including:

- Enumerating local and network drives.

- Escalating privileges where necessary.
- Disabling antivirus and security software.
- Deleting Windows Shadow Volume Copies.
- Exfiltrating confidential business information.
- Encrypting files using strong encryption algorithms.
- Appending REvil-specific file extensions.
- Dropping ransom notes in encrypted directories.
- Communicating with attacker-controlled infrastructure for operational updates.

10.8 Indicators of Compromise (IOCs)

IOC Type	Observation
Malware Name	REvil (Sodinokibi)
Delivery Method	Phishing, RDP, VPN, Supply Chain
File Extension	Variant-specific encrypted file extensions
Registry Activity	Startup and service modifications
Process Activity	Backup service termination
File System	Shadow Copy deletion
Network Activity	Large outbound data transfers before encryption

10.9 Business Impact

REvil attacks have resulted in substantial operational and financial consequences.

Major impacts include:

- Business interruption across multiple industries.
- Theft of confidential corporate information.
- Supply chain disruptions.
- Multi-million-dollar ransom demands.
- Regulatory investigations and compliance challenges.
- Damage to customer trust and organizational reputation.
- Increased cybersecurity recovery expenses.

10.10 Technical Impact

Technical consequences included:

- Enterprise-wide file encryption.
 - Data exfiltration before encryption.
 - Loss of access to business-critical systems.
 - Deletion of recovery mechanisms.
 - Lateral movement across enterprise environments.
 - Compromise of administrative accounts.
 - Extended recovery and forensic investigation efforts.
-

10.11 Detection Techniques

SOC analysts can detect REvil activity through:

- Monitoring abnormal RDP authentication attempts.
 - Detecting privilege escalation.
 - Monitoring suspicious PowerShell execution.
 - Identifying large outbound data transfers.
 - Detecting Windows Shadow Copy deletion.
 - Monitoring mass file encryption.
 - Endpoint Detection and Response (EDR) alerts.
 - Security Information and Event Management (SIEM) correlation rules.
-

10.12 MITRE ATT&CK Mapping

Technique ID	Technique
T1566	Phishing
T1078	Valid Accounts
T1021	Remote Services
T1486	Data Encrypted for Impact

T1490	Inhibit System Recovery
T1041	Exfiltration Over Command and Control Channel
T1059	Command and Scripting Interpreter

10.13 Prevention and Mitigation

Organizations can reduce the risk of REvil attacks by implementing the following security controls:

- Enable Multi-Factor Authentication (MFA).
 - Restrict Remote Desktop Protocol (RDP) access.
 - Apply software patches and updates promptly.
 - Conduct regular vulnerability assessments.
 - Maintain offline and immutable backups.
 - Deploy Endpoint Detection and Response (EDR) solutions.
 - Implement network segmentation.
 - Monitor outbound network traffic for data exfiltration.
 - Perform continuous security monitoring and threat hunting.
 - Develop and regularly test an incident response plan.
-

10.14 Lessons Learned

The REvil ransomware campaigns demonstrated that ransomware groups increasingly combine data theft, encryption, and supply chain compromise to maximize their impact. Organizations should adopt a layered security approach that includes strong identity protection, timely patch management, secure remote access, network segmentation, continuous monitoring, and resilient backup strategies. Effective incident response planning and regular cybersecurity exercises are essential to reduce recovery time and minimize business disruption.

11. Malware Breach 9 – DarkSide Ransomware

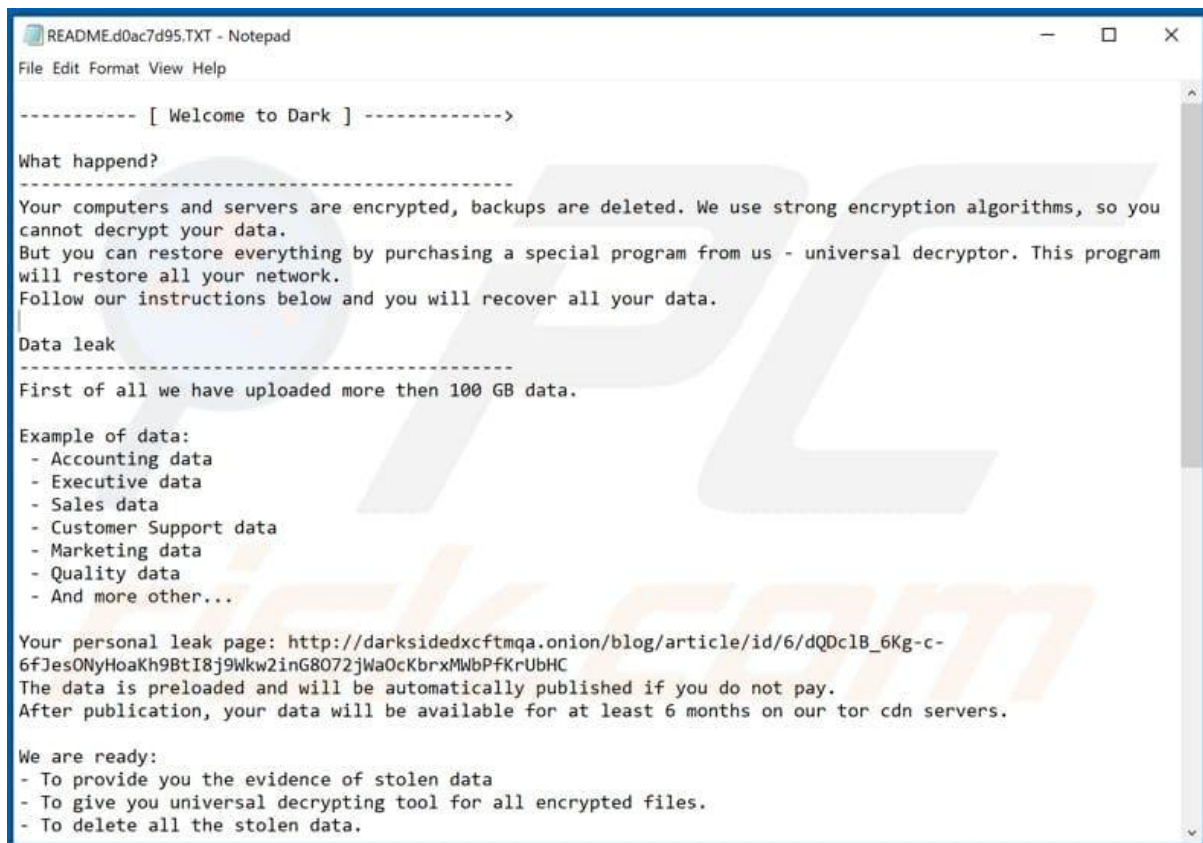


Figure 17 DarkSide Ransom Note

11.1 Background

DarkSide is a **Ransomware-as-a-Service (RaaS)** malware family that emerged in **August 2020**. It quickly gained attention due to its highly targeted attacks against large enterprises and critical infrastructure. Unlike opportunistic ransomware campaigns, DarkSide focused on organizations that were more likely to pay substantial ransoms.

DarkSide became globally recognized after the **Colonial Pipeline attack in May 2021**, which temporarily disrupted fuel distribution across the eastern United States. The attack caused widespread fuel shortages, operational disruption, and significant financial losses, demonstrating how ransomware can impact national critical infrastructure.

DarkSide operators typically employed a **double-extortion** strategy by stealing sensitive data before encrypting victim systems. If organizations refused to pay the ransom, the stolen information was threatened with public release on dedicated leak websites.

11.2 Malware Overview

Attribute	Details
Malware Name	DarkSide
Malware Family	Ransomware
Malware Type	Ransomware-as-a-Service (RaaS)
First Observed	August 2020
Operating System	Microsoft Windows
Primary Objective	File Encryption and Data Extortion

11.3 Threat Actor

DarkSide is operated by the **DarkSide cybercriminal group**, which provides ransomware services to affiliates under the Ransomware-as-a-Service model. The group primarily targeted large organizations and critical infrastructure for financial gain.

11.4 Timeline

Date	Event
August 2020	DarkSide ransomware first identified
Late 2020	Enterprise ransomware campaigns increased
May 2021	Colonial Pipeline ransomware attack
May 2021	DarkSide infrastructure disrupted after international law enforcement pressure

11.5 Attack Vector

DarkSide commonly gains initial access through phishing emails, compromised credentials, exposed Remote Desktop Protocol (RDP) services, Virtual Private Network (VPN) vulnerabilities, or exploitation of unpatched internet-facing systems.

Attack Process

1. Attackers gain initial access through phishing emails, stolen credentials, or vulnerable remote access services.
2. Administrative privileges are obtained.
3. Internal network reconnaissance is performed.

4. Sensitive organizational data is collected and exfiltrated.
5. Security software and backup services are disabled.
6. DarkSide encrypts files across enterprise systems.
7. Victims receive a ransom note demanding cryptocurrency payment.

11.6 Initial Point of Compromise

The initial compromise generally occurs through compromised credentials, phishing emails, exposed RDP services, or exploitation of VPN vulnerabilities. Once attackers establish access, they move laterally through the network, identify critical systems, and deploy the ransomware payload.

11.7 Technical Behaviour

After execution, DarkSide performs several malicious activities:

- Enumerates local and network drives.
 - Escalates privileges where necessary.
 - Terminates antivirus and backup-related processes.
 - Deletes Windows Shadow Volume Copies.
 - Exfiltrates sensitive business information before encryption.
 - Encrypts files using strong cryptographic algorithms.
 - Renames encrypted files using DarkSide-specific extensions.
 - Drops ransom notes in encrypted directories.
 - Uses legitimate administrative tools to move laterally across the network.
-

11.8 Indicators of Compromise (IOCs)

IOC Type	Observation
Malware Name	DarkSide
Delivery Method	Phishing, RDP, VPN Exploitation
File Extension	Variant-specific encrypted file extensions
Registry Activity	Startup and service modifications

Process Activity	Antivirus and backup service termination
File System	Shadow Copy deletion
Network Activity	Large outbound data transfers prior to encryption

11.9 Business Impact

DarkSide attacks have caused major operational and financial consequences.

Major impacts include:

- Disruption of critical infrastructure.
 - Temporary shutdown of essential business operations.
 - Financial losses due to ransom payments and recovery efforts.
 - Theft of confidential corporate information.
 - Supply chain interruptions.
 - Damage to customer trust and corporate reputation.
 - Increased regulatory scrutiny and compliance costs.
-

11.10 Technical Impact

Technical consequences included:

- Enterprise-wide file encryption.
 - Data exfiltration before encryption.
 - Deletion of recovery mechanisms.
 - Compromise of privileged accounts.
 - Service outages across critical infrastructure.
 - Extensive forensic investigations and recovery operations.
 - Long-term system restoration efforts.
-

11.11 Detection Techniques

SOC analysts can detect DarkSide activity through:

- Monitoring abnormal authentication attempts.
- Detecting privilege escalation.

- Identifying suspicious PowerShell and command-line activity.
- Monitoring Windows Shadow Copy deletion.
- Detecting unusual outbound data transfers.
- Monitoring mass file encryption events.
- Endpoint Detection and Response (EDR) alerts.
- Security Information and Event Management (SIEM) correlation rules.

11.12 MITRE ATT&CK Mapping

Technique ID	Technique
T1566	Phishing
T1078	Valid Accounts
T1021	Remote Services
T1486	Data Encrypted for Impact
T1490	Inhibit System Recovery
T1041	Exfiltration Over Command and Control Channel
T1059	Command and Scripting Interpreter

11.13 Prevention and Mitigation

Organizations can reduce the risk of DarkSide attacks by implementing the following security controls:

- Enable Multi-Factor Authentication (MFA).
- Restrict Remote Desktop Protocol (RDP) access.
- Apply software patches promptly.
- Conduct regular vulnerability assessments.
- Maintain secure offline backups.
- Deploy Endpoint Detection and Response (EDR) solutions.
- Implement network segmentation.
- Monitor outbound traffic for signs of data exfiltration.
- Perform continuous threat hunting.

- Regularly test incident response and disaster recovery plans.
-

11.14 Lessons Learned

The DarkSide ransomware campaign highlighted the significant risks ransomware poses to critical infrastructure. The Colonial Pipeline incident demonstrated that attacks on operational technology and essential services can have far-reaching societal and economic impacts. Organizations should strengthen identity security, secure remote access, implement network segmentation, maintain resilient backups, and continuously monitor for early indicators of compromise. Regular incident response exercises and collaboration with threat intelligence partners are essential for improving organizational resilience against ransomware attacks.

12. Malware Breach 10 – SolarWinds SUNBURST Supply Chain Attack

SolarWinds Post-Build Verification

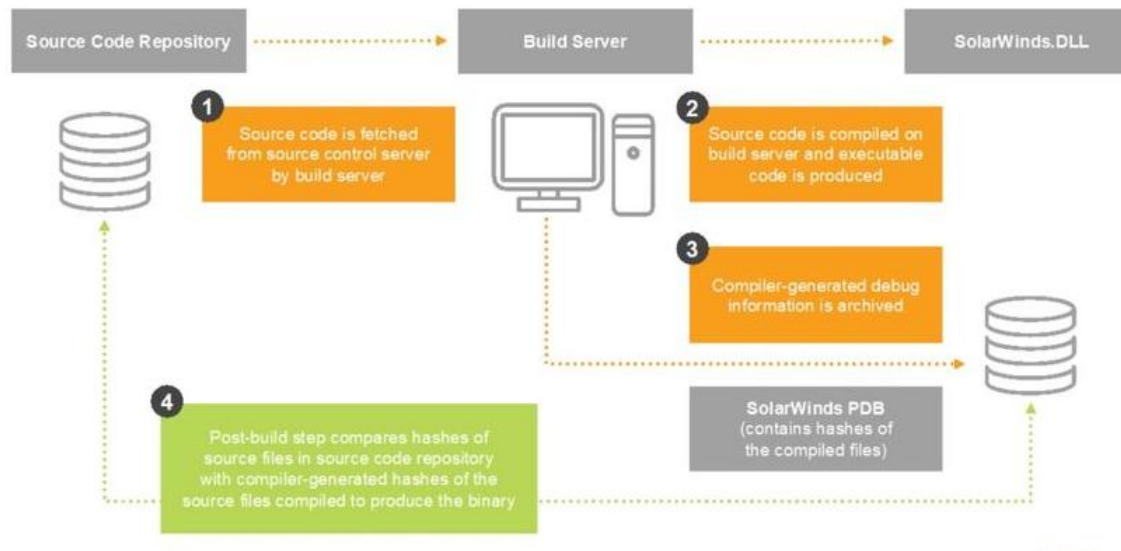


Figure 19: SolarWinds SUNBURST Attack Overview

12.1 Background

The SolarWinds SUNBURST attack is one of the most sophisticated cyber espionage campaigns ever discovered. The attack was publicly disclosed in **December 2020**, after security researchers identified malicious code embedded within legitimate updates of the **SolarWinds Orion IT management platform**.

Unlike traditional malware attacks that directly target victims, SUNBURST compromised the software supply chain by inserting a malicious backdoor into trusted software updates. Organizations that installed the infected Orion updates unknowingly deployed the malware within their own networks.

More than **18,000 organizations** worldwide downloaded the compromised software, including government agencies, technology companies, financial institutions, telecommunications providers, healthcare organizations, and critical infrastructure operators. The campaign demonstrated how trusted software updates can become an effective attack vector for highly advanced threat actors.

12.2 Malware Overview

Attribute	Details
-----------	---------

Malware Name	SUNBURST
Malware Family	Backdoor / Supply Chain Malware
Malware Type	Supply Chain Attack
First Observed	December 2020
Operating System	Microsoft Windows
Primary Objective	Cyber Espionage and Persistent Access

12.3 Threat Actor

The SUNBURST campaign has been publicly attributed by multiple governments and cybersecurity organizations to **APT29 (Cozy Bear)**, a sophisticated nation-state threat group associated with the Russian Foreign Intelligence Service (SVR). The operation primarily focused on long-term intelligence collection rather than financial gain.

12.4 Timeline

Date	Event
September 2019	Attackers begin compromising SolarWinds environment
March–June 2020	Malicious Orion updates distributed
December 2020	FireEye discovers SUNBURST backdoor
December 2020	Public disclosure of the SolarWinds compromise
2021	Global investigation and remediation efforts continue

12.5 Attack Vector

The attack originated through a **software supply chain compromise**. Attackers infiltrated the SolarWinds software development environment and inserted malicious code into legitimate Orion software updates.

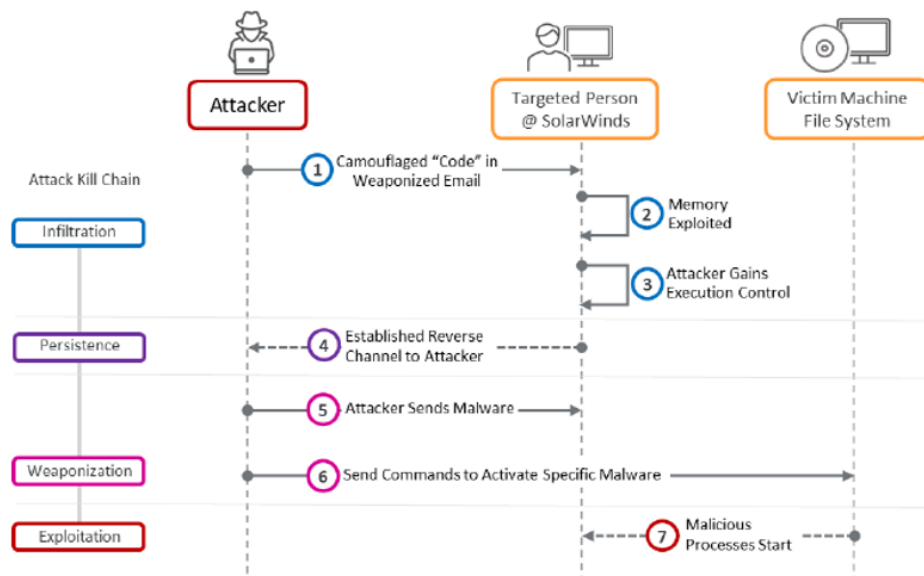


Figure 20: SolarWinds Supply Chain Attack Flow

Attack Process

1. Attackers compromised the SolarWinds software build environment.
2. Malicious SUNBURST code was inserted into Orion updates.
3. SolarWinds digitally signed and distributed the infected updates.
4. Organizations installed the trusted software update.
5. SUNBURST established a stealthy backdoor.
6. The malware communicated with attacker-controlled command-and-control (C2) servers.
7. Selected targets experienced further compromise through additional malware deployment and credential theft.

12.6 Initial Point of Compromise

Unlike phishing or ransomware attacks, the initial compromise occurred within the **SolarWinds software development environment**. Victim organizations became infected by the installing legitimate software updates that unknowingly contained the SUNBURST backdoor.

12.7 Technical Behaviour

After installation, SUNBURST performed several stealthy operations:

- Remained dormant for several days to avoid detection.

- Collected system and network information.
- Established encrypted communication with command-and-control (C2) servers.
- Received attacker instructions remotely.
- Downloaded additional malicious payloads for selected targets.
- Used legitimate SolarWinds processes to blend into normal activity.
- Attempted to evade detection through carefully timed communications and minimal system impact.

Unlike ransomware, SUNBURST focused on maintaining persistent access and gathering intelligence without disrupting normal business operations.

12.8 Indicators of Compromise (IOCs)

IOC Type	Observation
Malware Name	SUNBURST
Malware Type	Backdoor
Delivery Method	Compromised Software Update
Process	SolarWinds Orion Process
Registry Activity	Persistence-related configuration changes
Network Activity	Communication with command-and-control servers
DNS Activity	Suspicious DNS queries to attacker-controlled domains

12.9 Business Impact

The SolarWinds attack had a significant global impact.

Major impacts include:

- Exposure of sensitive government and corporate information.
- Long-term unauthorized access to enterprise networks.
- Supply chain compromise affecting thousands of organizations.
- Extensive incident response and forensic investigations.
- Financial losses associated with recovery efforts.
- Damage to trust in software supply chains.

- Increased cybersecurity investment worldwide.
-

12.10 Technical Impact

Technical consequences included:

- Persistent remote access to victim environments.
 - Credential theft and privilege escalation.
 - Lateral movement within enterprise networks.
 - Deployment of additional malware payloads.
 - Compromise of sensitive information.
 - Long-term monitoring of victim activities.
 - Extensive forensic analysis and system remediation.
-

12.11 Detection Techniques

SOC analysts can detect SUNBURST activity through:

- Monitoring unusual DNS requests.
 - Identifying unexpected outbound communications.
 - Detecting suspicious SolarWinds Orion process behavior.
 - Monitoring abnormal authentication events.
 - Correlating Endpoint Detection and Response (EDR) alerts.
 - Threat hunting using Indicators of Compromise (IOCs).
 - Security Information and Event Management (SIEM) log correlation.
-

12.12 MITRE ATT&CK Mapping

Technique ID	Technique
T1195	Supply Chain Compromise
T1071	Application Layer Protocol
T1105	Ingress Tool Transfer
T1078	Valid Accounts

T1027	Obfuscated Files or Information
T1003	OS Credential Dumping
T1082	System Information Discovery

12.13 Prevention and Mitigation

Organizations can reduce the risk of supply chain attacks by implementing the following security controls:

- Verify software integrity and digital signatures before deployment.
 - Apply Zero Trust security principles.
 - Continuously monitor third-party software behavior.
 - Segment critical enterprise networks.
 - Deploy Endpoint Detection and Response (EDR) solutions.
 - Monitor DNS and outbound network traffic.
 - Conduct regular supply chain security assessments.
 - Implement Multi-Factor Authentication (MFA).
 - Perform continuous threat hunting and log analysis.
 - Maintain an up-to-date incident response plan.
-

12.14 Lessons Learned

The SolarWinds SUNBURST incident demonstrated that trusted software vendors can become attractive targets for sophisticated threat actors. Organizations should adopt a defense-in-depth strategy that includes continuous monitoring, Zero Trust architecture, supply chain risk management, strong identity protection, and proactive threat hunting. Even trusted software updates should be validated and monitored for unusual behavior. Collaboration between vendors, customers, and cybersecurity agencies is essential for identifying and responding to large-scale supply chain compromises.

13. Conclusion

The analysis of these ten major malware breaches highlights how cyber threats continue to evolve in complexity, scale, and impact. Despite using different attack techniques, most incidents exploited common weaknesses such as unpatched systems, phishing emails, stolen credentials, and supply chain vulnerabilities. This study emphasizes the importance of

proactive security measures, continuous monitoring, timely patch management, user awareness, and a well-defined incident response plan. Learning from these real-world cases enables organizations to strengthen their cybersecurity posture and better defend against future malware attacks.
